INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 2 Scenario-Based Assignment:

GRC Regulatory Environment and Standards

Student Name: Najma Abdi Omar

Reg. No: **2025/GRC/10331**

Date: 01/08/2025

Scenario 1. Global E-Commerce Platform

Executive Summary:

TechMart Global is a growing e-commerce platform in the United States with a global audience including Canada, EU, UK and Australia and data centers in US and Singapore. We explore the regulation and Industry Standards applicable, undertake the GDPR Assessment and finally conduct a compliance recommendation.

Regulatory Identification:

Applicable Regulation	Country	Reason and Triggers
Personal Data Protection ACT(PDPA)	Singapore	A world-wide platform with client-base and data servers in Singapore.
California Consumer Privacy Act(CCPA), and California Privacy Rights Act(CPRA)	USA	An E-commerce platform with clients information and Data Servers in USA
GDPR, (UK GDPR-Post brexit), PIPEDA, Privacy Act Amendments,	EU, UK, Canada, Australia	Storing and processing personal information and Serving Customers in the EU, United Kingdom, Canada and Australia
Cross-Border Transfer Regulations	Global	Serves Cross-border clients (Global Clientele), stores, processes and also exports data across platforms and countries.

GDPR Compliance Assessment:

Legal basis for processing customer data: Under GDPR, Organizations must have valid reason for processing personal data, TechMart, a private entity, must establish what is applicable under: **Consent,** clients must give consent on how their data is processed e.g. marketing and recommendations sent, **Contract** in order to process and complete the sale agreement, **legal obligation** necessary for processing regulatory reporting applicable e.g. tax compliance records, **Legitimate Interest** for processing of browsing history and session cookies to curate a customer experience.

Data subject rights implementation requirements:

TechMart must ensure that the clients have means to exercise their rights under data protection, clients have a **right to be informed** what data is being collected and purpose and related issues, make it easy or provide a platform/ systems for **ease of access** and create copies, right to **rectify mistakes** and **inaccuracies** easily, implement data retention policies and procedures to delete data for the subjects to exercise **the right to be forgotten**, mechanism that allow clients **restrict processing** of data, create ways ensuring **data portability** clients can copy or move data, means to **objections of use** e.g. unsubscribe from an advertising email, **object automated decision** making i.e. AI deciding which profile category to place them etc. overall TechMart must also ensure they **train their staff** so that they can support requests, carry out data subject obligation, respond within a certain timeframe or explain a need for an extension

International data transfer compliance: simply means that data that leaves EU must be kept under same standard of protection and TechMart have to prove compliance otherwise they might be subject to fines**.** TechMart must undertake **transfer impact assessments** and **implement necessary measures** where needed ensuring level compliance and safety measures. Compliance include: **Adequacy Decisions**: Check destination country has been cleared by EU standards meeting adequate levels of data protection. **Appropriate Safeguards:** ensure, in the absence of adequacy, mitigating controls in place like SCCs, BCRs and approved code of conducts. Or in absence of the above have **Derogations for specific situations,** where it is absolute necessary for purpose of support TechMart can get **absolute consent** from the clients for

transfers. Finally, **in one-off transfers** TechMart must ensure appropriate safeguards are configured when dealing with such for example sending customer details to the customer care based in India.

Potential compliance gaps and risks:

Based on the data collected, where it is stored and processed, how long it stored TechMart is subject to potential gaps outlined in the below table**:**

Detail from Scenario	**Potential Gap**
International Data Transfers- Data moved from EU, UK, Canada and Australia to Singapore, USA and potentially India	Inadequacy, lack of safeguards or absolute consent
Retaining Client Data Indefinitely	Clear data retention policies
Sharing customer analytics	Clear legal basis
Cookies and Tracking Technologies use	Clear consent and user right to be informed
No mention of a DPO	Potential lack in governance and policy guide

Compliance Recommendations

Immediate: need to stop the immediate gaps that are high risk and quick wins: cookie consents, indefinite data retention, appropriate privacy notices and document legal basis for collected and stored data. Because this involves website updates it is likely low cost apart from the data retention which might include revision and classification of data so roughly $5000

Short-Term: within 6 months, focusing on systems and secure transfers: Modify the website to cater for the rights of the clients to their data, review all the gaps listed under international transfers and implement safeguarding controls for India and Singapore, put in place data processing agreements with third party and global offices, review cookie management, invest in employee training. estimated as $ 30-40,000 because of legal consultation and reviews.

Long Term: within a year: this timeframe is to ensure privacy by design, by review and implementing global privacy framework cutting across all the regulations, undertake data clean up inclusive of inventory and data mapping, privacy by design for all projects, monitor and update policies as required and consider a global certification like ISO, invest in audit and compliance and Employ a data privacy officer: this will be a big investment because of the cost of certification and employing a DPO, estimate $250K-$350K.

Scenario 2: Healthcare Technology Startup

Executive Summary:

Medconnect, a healthcare technology startup with mobile application allowing on the go interaction between Patients and data. Based in USA with plans to expand to Canada and EU with use of Cloud and AI technologies. Experienced a quickly contained minor breach. Below we analyze Regulatory Frameworks, undertake a data security and Privacy Assessment, create Incident Response plan applicable to Medconnect.

HIPAA requirements and applicability:

Medconnect, covered entity under HIPAA due to the direct access to patient information. Requirements include:

HIPAA Privacy Rule: protection of health information catering for individual rights like access and amendment, restriction of use of PHI, and dictates how the PHI is accessed, and used.

Security Rule: outline administrative, physical and technical safeguards ensuring security of ePHI.

HIPAA Breach Notification: The right to be notified of a breach within 60 days of discovery, Medconnect has an obligation enforce response and notice policy of breaches.

State-level healthcare privacy laws: For Medconnect to comply it must investigate other state requirements on privacy and breach notifications like e.g. CCPA.

International regulations for planned expansion: with plans to expand to Canada and EU, Medconnect has to comply with GDPR in EU and PIPEDA in Canada.

Industry-specific compliance considerations: Since the industry is health-care, other than HIPAA Medconnect needs to comply with Health Information Technology for Economic and Clinical Health (HITECH) Act because of interaction with Tech, Medical Device Regulation (MDR) in Europe and Good Clinical Practice (GCP) Standards.

Data Security and Privacy Assessment

Technical safeguards required under HIPAA Security Rule: To comply with HIPAA and in reviewing the current set up, this are the **technical controls** that Medconnect needs to enforce to protect the ePHI: **Access control** ensuring unique users, emergency access and auto encrypt/decrypt procedures. **Audit Controls:** Have audit trails to record and examine all activities, **Integrity Controls:** to avoid improper alterations or destruction, **authentication:** Verify the authenticity of user or person accessing system. And **Transmission security** to protect data in transit.

Administrative and **physical** safeguards implementation: have administrative controls in place to assist in enforcing proper handling of ePHI, measures like security awareness training, incident procedures, security management and information access, have policies, procedures and workforce training measures that ensure HIPAA compliance. Physical safeguards are measures taken to physically safeguard equipment, location and electronic systems to protect from unauthorized access, this entail facility access controls, workstation use and security and device and media control.

Business associate agreement requirements: integrations with EHR systems, under HIPAA it is required that there be established contract between the covered entity(Medconnect) and Business associates on permissions and required uses and disclosures of PHI.

Breach notification obligations and procedures

Establish breach notification obligations and procedures: Covered entities must notify affected individuals without reasonable delay and no later than 60 days of discovery, notification via first-mail or e-mail depending on customer preference and for **breaches affecting** more than 500 individuals notify HHS and prominent media outlets serving the area. Less than 500 affected, maintain log and notify secretary annually. Business

associates must also notify covered entities and give details of individuals affected. **Notification include** description of breach, information leaked, how to protect oneself and steps covered entity is doing to avoid repeat case, provide contact information for additional questions.

Incident Response and Remediation

Response plan for the security incident:

Immediate containment and assessment steps

Includes evaluation of the breach and extent, **Immediate actions**: Isolate affected System, disable compromised user and activate Backup if major system is affected. Verify number of users affected and details of the breach.

Regulatory notification requirements and timelines:

Adopt the steps as below:

a. <500 users affected: Notify users of the breach as soon as possible after completing investigations, no later than 60 days after discovery and keep log for annual report.

b. >500 users: Notify the users, media and the HHs

c. Notification Details: Include breach description, information leaked, how to protect yourself, what Medconnect is doing to investigate, mitigate and prevent future breaches and have dedicated contacts for customers to reach out.

Patient communication strategy:

Notified using their preferred mode of communication (First Mail/ E-Mail)

Communication must be clear describing details of breaches

Trained and ready staff to answer questions on the details of the breach

Establish dedicated lines for the patients to reach out for further guidance

Communicate status updates on the breach, containment, extent, recovery etc. to critical teams and media, communicate even when there is no update to avoid public panic.

Long-term security improvements to prevent future incidents

Document lesson learnt,

Improved system security

Encrypt data in all states

Continuous audit, access reviews and Privileged Access Monitoring

Review Controls: Technical, Administrative and Physical

Continuous user awareness training, Vulnerabilities check and patch management.

Mock Incident response to avoid weak or confused response.

Scenario 3: Financial Services Firm

Executive Summary:

SecureBank, a midsized financial services firm offering banking services, processing millions of payment card transactions, it offers multiple banking channels and CRM, with third party integrations. With increasing cyber threats and attempted breaches, we are undertaking an exercise to address regulatory compliance to support business growth objectives.

Multi-Regulatory Compliance Analysis

Multiple regulatory frameworks compliance:

PCI DSS requirements for payment card data: SecureBank has to comply with PCI DSS because it deals with card holder information, processing millions of card transactions.it has to uphold multiple security controls ensuring secure card information, controls safeguard cardholder data environment, connected systems, sensitive cardholder data and authentication data, all this ensures reduced fraud and theft.

Banking regulations for financial data protection: Banks should secure customer data, keep clients safe from breaches, fraud and guide on how to fix in case of an incident. FINRA rules BCBS Standards etc. Card Transactions and Card Holder Data are part of the client base to be secured.

Consumer protection laws for financial services: Laws designed to protect customers from unfair, deceptive and abusive practices by financial institutions, customers have clear information protecting from things like hidden fees, requiring transparency when undertaking any type of transaction.

Cross-regulatory compliance challenges and solutions:

SecureBank has to comply with various regulations and Industry standards, sometimes having conflicting requirements and best practices, regulations are also resource intensive, they require financial and human resources, complex technology needing high technical staff and extensive training limiting implementation, risk of different sectors working in Silos and creating split effort. The solution is to harmonize compliance approaches, by developing policies and procedures that address the highest level controls, adopt Risk-Based compliance that way high risk are eliminated and technical efforts are prioritized, encouraged stakeholder communication and collaboration to avoid working in Silos and implementation delays.

PCI DSS Implementation Plan

Comprehensive PCI DSS Compliance Strategy:

The 12 PCI DSS requirements and their application to SecureBank

- **Install and maintain network security control**- ensures traffic restriction to and from cardholder environment and segmented environment
- **Apply secure configurations to all system components**, ensuring systems and servers hardening.
- **Protect Stored account data**: data minimization, encryption of data at all states.
- **Protect Data in Transit**- Business must ensure admin access is restricted.

- **Protect all systems and networks from malicious software**: up to date antivirus and protective policies.
- **Develop and maintain secure systems and software**: continuous check for vulnerabilities.
- **Define Access Control**: Limits access to any part of system logical and physical.
- **Identify users and authenticate access to system**: this ensures secure cardholder data environment
- **Restrict Physical access to card Holder data:** Implement appropriate physical security
- **Log and monitor all access to system components and card holder data**: Provide an audit trail
- **Test security of systems and network regulatory**: Ensure security and beyond paper policy.
- **Support Information security with organizational policies and programs**: have a documented policy.

Compliance level determination and validation process

compliance validation is based on transaction volume and experience in data breach, SecureBank processes millions of card transaction falling under level 1 compliance level. **Requirements:** Annual report on compliance (ROC), by a qualified security assessor, internal security assessor, quarterly network scans by an approved scanning vendor and attestation of compliance

Technical and procedural controls implementation:

Using strong technical controls to stop attacks with tools and systems, procedural controls to make sure people use those tools correctly and eliminate weak links. **Technical:** Implement access controls, system hardening, maintain vulnerability management program, log and monitoring systems, implement DLP solutions and protect data in all its states. **Procedural:** Maintain an InfoSec policy addressing gaps arising from weakness such as awareness trainings, incident response plan, screening potential hires etc.

Ongoing monitoring and maintenance requirements:

In order to maintain a secure environment, it is recommended to continuously monitor and maintain systems, network and policies. This by automating, implementing and recording audit trails for all system components and changes or actions taken on card holder environment. Ensuring security policies and procedures for monitoring are in use, in place and known to everyone. Have an audit trail to know who did what, when, how and where.

Risk Management and Continuous Improvement

Design a risk management framework that addresses:

Because of the multi-regulation and industry specific standards and requirements, it is recommended we approach this with a framework that meets the requirements to mitigate all types of risk from system to 3rd party management.

- **Regular compliance assessments and gap analysis**

Ensures continuous compliance and monitoring of the environment enabling maintenance of security standard through: Quarterly gap assessment (VAPT and Audits), remediation plans (Patch management), management reporting and log monitoring for network and system access.

- **Vendor management and third-party risk assessment:**

Objective is to ensure reduced third party risk, achieved by: Following procurement and due diligence when onboarding the vendor, regular vendor reviews checking compliance with secure policies and state regulations including license validation, maintaining access policies that check who access what and record session logs, follow change management policies, regular audit of third party.

• **Employee training and awareness programs**

Objectives: reduce risks associated with insider threat due to negligence or ignorance: Perform regular employee awareness training on policies and cyber safety, role-based training tailored to groups, verify effectiveness through assessments, address specific regulation and industry requirement.

• **Incident response and business continuity planning:**

Objective: Confirm that business can optimally operate in times of crisis with minimal disruption: achieved through: Identifying critical systems, confirming regular backups for all systems, employing an incidence response playbook that address the roles and responsibilities of each key player, address communication strategies, training and awareness, undertaking table-top exercise to role play response plans, identify DR sites and alternative work locations, have policies in place and ensure every one is aware, test backups to ensure continuity.

Scenario 4: International Manufacturing Corporation

Executive Summary:

Global Manufacturing Corp, is a multinational company with operations in North America, Europe and Asia. To achieve comprehensive security, the organization is Pursuing ISO certifications, we are developing a unified approach to regulatory compliance and risk management, below we review ISO standard Integration Strategy. Cross-jurisdictional compliance framework and asses risk associated with emerging technologies.

ISO Standards Integration Strategy:

Develop a multiple ISO standard implementation strategy: check for the various strength and overlapping controls in all the frameworks, by integrating the ISO 31000's risk management framework (all risk all organizations) with ISO 270001 information security controls and the privacy requirements from ISO 27701, ensuring streamlined compliance, reduce effort and resource complexity and duplication (avoiding Siloed work), have governance addressing data protection, security and risk. Employ and define governance and

scope, get executive by in and eliminating siloed effort, adopt a common risk-based framework by following ISO 31000 principles of identifying, analyzing, evaluating and treating risk around information security and data protection. Implement unified policies, controls and processes, awareness training seeking to undertake cross-framework requirements ensuring employees understand and adhere to unified approach and have a system to monitor audit and improve on the framework. Combine the requirement as below:

• ISO/IEC 27001 for information security management: Provides a framework for establishing, implementing, maintaining and continually improving an ISMS.

• ISO 31000 for risk management: effective risk management for all types of risk.

• ISO/IEC 27701 for privacy information management: an extension to ISO 27001 and ISO 27002 for privacy information management. Provides a framework for establishing, implementing, maintaining, and continually improving a Privacy Information Management System (PIMS).

• **Integration approach and implementation timeline:**

Implied in the strategy: Involves: harmonizing policies and procedures, having centralized risk register and gap assessment, centralized and uniform training, alignment of risk and control framework like how we adopt the ISO 31000 process to either ISO 27001 security risk or 27701 privacy risk.

Timelines: this will take a minimum of 6 months if all approvals and timelines are not affected by external factors:

• **Benefits and challenges of multi-standard certification:**

Challenges: High Resource and cost implications, both technology and human resources investment, coordination when implementing various controls can be complex and ambiguous if not approached correctly, culture resistance to multiple change at once needing strong management support, continuous monitoring and maintenance can be hard on teams especially since frameworks continuously evolve, multiple compliance means multiple audit which can be tiring and straining on teams if not correctly handled or proper training on documentation done. With all this challenges, we still have **benefits**: enhanced security and privacy, shared

structure enables reuse of policies and saves times as opposed to stand alone compliance, an organization stands more ready for regulation audits, they have a strong reputation and trust by proving they are multi-certified, improves company culture based on the numerous training undertaken.

Cross-Jurisdictional Compliance Framework:

Design a compliance framework that addresses:

• **Regulatory variations across different countries and regions:**

Understand different regulations applicable to our organization and perform gap analysis addressing compliance limitations, classifying laws by applicable category in like financials or privacy etc. in our scenario these will be the applicable regulations in North America, EU and Asia e.g. EU's GDPR and Asia's PDPA, USA's CCPA, and CPRA.

• **Harmonization strategies for conflicting requirements:**

Ensure we adopt a framework that will not lead to conflict in compliance, we address the requirements that are required in one area and not compulsory in another by adopting the highest standard addressing security, privacy and state requirement and regulations.

• **Unified policies and procedures that meet multiple regulatory standards**

The goal here is to adopt a flexible organizational policy that aligns with ISO requirements and is applicable to all global standards, while addressing the outliers for example the data breach reporting requirements (maximum days of not replying).

• **Governance structure for ongoing compliance management:**

In our scenario, presence in three offices needs establishing global compliance office with presence in all the key countries, assign control owners in all states, departments and offices, have policies in place addressing audit (how frequent, internal or external). Centralized monitoring that ensures we are in sync as an organization.

Emerging Technology Risk Assessment

Assess the regulatory and compliance implications of implementing new technologies:

Emerging technologies are driving new regulatory approaches:

• **IoT devices and data collection considerations**: This increases the attack surfaces due to increased adoption and lack of clear guidelines on the kind of data collected and usage leading to blurred lines in security, privacy and user and product safety. We need to have regulations that address key areas ambiguous in nature like this to ensure proper risk management.

• **Industry 4.0 and operational technology security:** This addresses smart technologies in factories and industries, hardware and software that runs physical equipment. Introducing new vulnerabilities in critical systems; we should adopt policies aiming to reduce risk by enforcing network segmentation and continuous audit, monitoring and restriction of physical access.

• **Data sovereignty and cross-border data transfer issues:** addresses issues in cloud computing where questions of where data is stored, how transfers are made and what controls are in place to safeguard security and privacy. We should create policies that address this key issues and specify how to vet or audit a service provider.

• **Future regulatory trends and preparation strategies**: Risk is evolving, threats and attack surfaces are expanding and the threat actors are finding new ways to exploit emerging, new and undiscovered zero day vulnerabilities, there is also emerging trends in the adoption of AI and globalization of industries. There is need to adopt flexible and smart policies that are continuously monitored and improved, globalization of regulations where we have harmonized controls that cut across regulations and industry standards, overall risk is evolving so should our policies and adoption.

Credit: The answers provided here have been in consultation with week 2 study materials, all credits to the main material * unless otherwise stated.